

ASSIGNMENT-

INTRODUCTION:

In this situation, I would follow the Responsible (coordinated) Vulnerability Disclosure (RVD/CVD) process, balancing public safety with the Vendor a fair opportunity to fix the issue

Steps to follow

1. Verify and document the vulnerability

→ Confirm that the vulnerability is genuine and reproducible

→ Record technical details, affected software version
Proof of concept (POC), and potential impact

→ Keep all evidence confidential

2. Attempt Vendor Communication

→ Continue contacting the vendor through official security emails, support channel, and CERT.
Contacts

→ Maintain records of all communication attempts

2. Notify Relevant Authorities

→ Since the software is used in medical devices inform the appropriate National CERT/CSIRT or health-care cybersecurity authority

→ This ensures patient safety if the vendor remains unresponsive

4. After 90 days

→ If the vendor still provides no response or mitigation after the standard 90 day disclosure period prepare a public advisory

→ The advisory should:

- Explain the affected product & risk
- include mitigation or workarounds
- Avoids releasing exploit code that could enable attack

5. Coordinate - If the vendor responds later

→ If the vendor responds after disclosure cooperate by validating the patch and updating the patch and updating the advisory

→ Justification for the 90-day Timeline

→ 0-30 days: initial vulnerability report and follow-up communication

→ 30-60 days: final opportunity for the vendor report with CERT / CSIRT if necessary

→ 60-90 Days: final opportunity for the vendor to acknowledge and fix the issue

→ after 90 days: limited public disclosure is justified